
Informe Pentesting

Cliente: **INSECUR S.A.** — Laboratorio: TryHackMe

Seguridad Aplicada a Sistemas de Información
Licenciatura en Sistemas de Información — Facultad de Informática y Diseño
Docente: Ing. Rodrigo Atilio Elgueta
Contratista: Julieta Ruppert
Ciclo Académico 2026

Índice

0.1. Datos generales	2
0.2. Pre-pentesting	2
0.3. Durante: Hallazgos por fase	4
0.4. Resumen ejecutivo de hallazgos	11
0.5. Post-pentesting: Recomendaciones	11
1. PROTOCOLO DE CONTINGENCIA	12
2. Anexos	13

0.1. Datos generales

Campo	Valor
Cliente	INSECUR S.A.
Contratista	Julieta Ruppert
DNI	46059824
Username TryHackMe	julietaruppertc
Email institucional	julietaruppertc@gmail.com
Sala Nivel 1 (Núcleo Obligatorio)	Basic Pentesting (10.64.154.72 / 10.64.154.42 ¹)
Sala Nivel 2 (Elección)	Vulniversity (10.66.142.132)
Branch en GitHub	Ruppert-Julieta
Fecha de inicio	03-10-2026
Fecha de cierre	06-10-2026

0.2. Pre-pentesting

Alcance del trabajo

El alcance técnico de la auditoría comprende exclusivamente las instancias virtuales desplegadas dentro del entorno controlado (sandbox) de la plataforma **TryHackMe** asignadas a la contratista:

- **Entorno A — Nivel 1 (Núcleo Obligatorio):** Salas *Pentesting Fundamentals* y *Basic Pentesting* (IPs asignadas dinámicamente en la subred del laboratorio: 10.64.154.72 / 10.64.154.42)
- **Entorno B — Nivel 2 (Sala de Elección):** Sala *Vulniversity* (Evaluación de seguridad en servidor Linux/Ubuntu con aplicativo web en puerto 3333/TCP, IP asignada: 10.66.142.132).

Queda estrictamente excluido cualquier activo, servidor, red local o infraestructura productiva fuera del túnel VPN del laboratorio (**tun0**).

Reglas de Enfrentamiento (ROE)

- **Conectividad y aislamiento:** Todas las pruebas se ejecutan exclusivamente a través de la interfaz de red virtual **tun0** provista por OpenVPN hacia las instancias asignadas.
- **Restricciones técnicas:** Se prohíben pruebas de Denegación de Servicio (DoS/DDoS) o agotamiento de recursos. Las pruebas de autenticación y fuerza bruta se limitan a tasas

¹La instancia de *Basic Pentesting* fue reasignada a una segunda dirección IP dinámica (10.64.154.42) entre la sesión de reconocimiento/escaneo (03-10-2026, 18:53–19:51h) y la sesión de explotación (03-10-2026, 20:26h en adelante), comportamiento propio del entorno sandbox de TryHackMe. Ambas IPs corresponden a la misma máquina objetivo y están dentro del alcance autorizado.

controladas (máximo 4 a 10 hilos concurrentes) deteniéndose ante el primer resultado válido.

- **Trazabilidad y confidencialidad:** Toda actividad queda registrada en la bitácora técnica sanitizando credenciales en texto plano ([REDACTED]), y las banderas (*flags*) se documentan únicamente mediante su hash SHA-256.
- **Notificación ante incidentes:** Ante cualquier interrupción no planificada del servicio en la máquina objetivo, se suspenden las pruebas de inmediato y se reinicia la instancia.

Autorización

Declaro contar con autorización expresa de la cátedra de *Seguridad Aplicada a Sistemas de Información* y de la organización simulada **INSECUR S.A.** para realizar evaluaciones de seguridad exclusivamente sobre los entornos de laboratorio de TryHackMe indicados en el alcance.

Metodología utilizada

Se adoptó una metodología híbrida basada en el estándar **NIST SP 800-115** (*Technical Guide to Information Security Testing and Assessment*) y el marco **PTES** (*Penetration Testing Execution Standard*), complementada con la guía **OWASP WSTG** para servicios web.

Justificación: NIST SP 800-115 estructura la evaluación en fases secuenciales (Planificación, Descubrimiento, Evaluación y Reporte) orientadas a la gestión de riesgos y continuidad del negocio, mientras que PTES y OWASP WSTG proveen los criterios técnicos para auditar configuraciones de servicios web, evasión de validaciones de carga de archivos y auditoría de permisos de sistema de archivos (SUID).

0.3. Durante: Hallazgos por fase

Entorno A: Evaluación Nivel 1 — Sala Basic Pentesting (IPs: 10.64.154.72 / 10.64.154.42)

Campo	Valor
ID del hallazgo	H-01
Fase	☐ Reconocimiento ☒ Escaneo ☐ Explotación ☐ Post-explotación
Descripción	Exposición de directorio oculto de desarrollo y notas internas en servidor web. Se identificó el directorio <code>/development/</code> accesible públicamente sin autenticación (IP: 10.64.154.72). En su interior se alojan los archivos <code>dev.txt</code> y <code>j.txt</code> , visibles mediante listado de directorio (<i>directory indexing</i>), que según su nombre y tamaño corresponden a notas de configuración interna de servicios (SMB y Apache) y de credenciales del usuario de inicial “J”.
Componente afectado	Servidor Web Apache (<code>http://10.64.154.72/development/</code> — Puerto 80/TCP)
Categoría (OWASP / CWE)	OWASP A05:2021 (Security Misconfiguration) / CWE-548 y CWE-200
CVE (si aplica)	No aplica (Falla de configuración)
CVSS estimado	☐ Bajo ☒ Medio ☐ Alto ☐ Crítico
Evidencia (captura / comando)	Archivos de registro en repositorio: <code>bitacora/gobuster.txt</code> y captura <code>evidencias/escaneo/escaneo_H-01.png</code> (listado del directorio <code>/development/</code>).
Herramienta utilizada	Gobuster v3.8.2 y navegador web
Impacto en la Tríada CIA	☒ Confidencialidad ☐ Integridad ☐ Disponibilidad
Salvaguarda propuesta	1. Eliminar del entorno de producción el directorio <code>/development/</code> y los archivos <code>dev.txt</code> y <code>j.txt</code>. 2. Deshabilitar el listado de directorios en Apache mediante la directiva <code>Options -Indexes</code>. 3. Implementar controles de acceso para entornos de prueba.
Riesgo residual tras aplicar	☒ Bajo ☐ Medio ☐ Alto

Campo	Valor
ID del hallazgo	H-02
Fase	☐ Reconocimiento ☒ Escaneo ☐ Explotación ☐ Post-explotación
Descripción	Sesiones nulas (Null Sessions) habilitadas, enumeración de usuarios por RID Cycling y política de contraseñas débil en Samba. El servicio SMB (IP: 10.64.154.72) permite sesiones anónimas sin credenciales al recurso <code>Anonymous</code> y consultas RPC. Mediante <i>RID Cycling</i> se identificaron las cuentas locales del sistema (<code>jan</code> , <code>kay</code> y <code>ubuntu</code>). Asimismo, se constató que la complejidad de contraseñas está deshabilitada (longitud mínima de 5 caracteres) y no existe umbral de bloqueo de cuenta (<i>Account Lockout Threshold: None</i>).
Componente afectado	Servicio Samba 4.15.13-Ubuntu (Puertos 139/TCP y 445/TCP)
Categoría (OWASP / CWE)	OWASP A07:2021 (Identification and Authentication Failures) / CWE-284 y CWE-521
CVE (si aplica)	No aplica (Debilidad de configuración y políticas)
CVSS estimado	☐ Bajo ☐ Medio ☒ Alto ☐ Crítico
Evidencia (captura / comando)	Archivo de registro en repositorio: <code>bitacora/enum4linux.txt</code> .
Herramienta utilizada	enum4linux v0.9.1
Impacto en la Tríada CIA	☒ Confidencialidad ☐ Integridad ☐ Disponibilidad
Salvaguarda propuesta	1. Deshabilitar sesiones nulas e invitados en <code>/etc/samba/smb.conf</code> (<code>restrict anonymous = 2</code> y <code>map to guest = Never</code>). 2. Restringir el acceso a los puertos 139/445 mediante firewall local (<code>ufw</code>). 3. Configurar políticas robustas de contraseñas y umbral de bloqueo de cuentas.
Riesgo residual tras aplicar	☒ Bajo ☐ Medio ☐ Alto

Campo	Valor
ID del hallazgo	H-03
Fase	☐ Reconocimiento ☒ Escaneo ☐ Explotación ☐ Post-explotación
Descripción	Ausencia de cabeceras de seguridad HTTP, divulgación de versión de servidor y filtración de inodes vía ETags. El servidor Apache/2.4.41 expone su versión exacta en las cabeceras HTTP, filtra información de inodes mediante la cabecera ETag y carece de cabeceras de seguridad (Strict-Transport-Security , X-Content-Type-Options , Content-Security-Policy , Referrer-Policy y Permissions-Policy). Verificado en ambas direcciones asignadas a la instancia (10.64.154.72 y 10.64.154.42).
Componente afectado	Servidor Web Apache/2.4.41 (Ubuntu) — Puerto 80/TCP
Categoría (OWASP / CWE)	OWASP A05:2021 (Security Misconfiguration) / CWE-693 y CWE-200
CVE (si aplica)	CVE-2003-1418
CVSS estimado	☒ Bajo ☐ Medio ☐ Alto ☐ Crítico
Evidencia (captura / comando)	Archivos de registro en repositorio: bitacora/nikto.txt , bitacora/nmap_inicial.txt y captura evidencias/escaneo/escaneo_H-03.png .
Herramienta utilizada	Nikto v2.6.0 y Nmap v7.99
Impacto en la Tríada CIA	☒ Confidencialidad ☐ Integridad ☐ Disponibilidad
Salvaguarda propuesta	1. Ocultar versión de Apache configurando ServerTokens Prod y ServerSignature Off. 2. Habilitar mod_headers para incorporar las cabeceras HTTP de seguridad faltantes. 3. Configurar FileETag MTime Size para excluir inodes de las cabeceras ETag.
Riesgo residual tras aplicar	☒ Bajo ☐ Medio ☐ Alto

Campo	Valor
ID del hallazgo	H-04
Fase	☐ Reconocimiento ☐ Escaneo ☒ Explotación ☐ Post-explotación
Descripción	Credenciales débiles en servicio SSH y ausencia de control de intentos fallidos. El servicio OpenSSH (IP: 10.64.154.42) permite la autenticación por contraseña sin aplicar bloqueo temporal ni limitación de tasa tras múltiples intentos fallidos. Esto permitió comprometer la cuenta del usuario local jan debido al uso de una contraseña de diccionario débil, obteniendo acceso interactivo remoto al servidor. El ataque se ejecutó con 4 tareas concurrentes y se detuvo automáticamente al hallar la primera credencial válida, conforme a las ROE establecidas.
Componente afectado	Servicio OpenSSH (Puerto 22/TCP) y cuenta de usuario jan
Categoría (OWASP / CWE)	OWASP A07:2021 (Identification and Authentication Failures) / CWE-307 y CWE-521
CVE (si aplica)	No aplica (Debilidad de credenciales y configuración de autenticación)
CVSS estimado	☐ Bajo ☐ Medio ☒ Alto ☐ Crítico
Evidencia (captura / comando)	Archivos de registro en repositorio: bitacora/hydra.txt (sanitizado) y bitacora/2026.pcapng (captura de tráfico SSH cifrado sobre tun0); capturas evidencias/explotacion/explotacion_H-04.png y evidencias/explotacion/explotacion_H-04.shell.png .
Herramienta utilizada	THC-Hydra v9.7, cliente OpenSSH y Wireshark v4.6.6
Impacto en la Tríada CIA	☒ Confidencialidad ☒ Integridad ☐ Disponibilidad
Salvaguarda propuesta	1. Exigir el cambio inmediato de la contraseña del usuario jan aplicando políticas PAM (pam_pwquality). 2. Deshabilitar la autenticación por contraseña en SSH (PasswordAuthentication no en /etc/ssh/sshd_config). 3. Implementar Fail2Ban para bloquear direcciones IP tras intentos de inicio de sesión fallidos.
Riesgo residual tras aplicar	☒ Bajo ☐ Medio ☐ Alto

Campo	Valor
ID del hallazgo	H-05
Fase	☐ Reconocimiento ☐ Escaneo ☐ Explotación ☒ Post-explotación
Descripción	Permisos de lectura excesivos en clave privada SSH (id_rsa), frase de paso débil y almacenamiento de credenciales en texto claro (pass.bak). En la fase de post-explotación, a partir del acceso obtenido en H-04, se verificó que el directorio <code>/home/kay/.ssh/</code> y la clave privada RSA del usuario privilegiado <code>kay</code> tenían permisos de lectura abiertos a otros usuarios locales (0644). Además, su frase de paso utilizaba una palabra débil de diccionario y el archivo <code>/home/kay/pass.bak</code> almacenaba la contraseña maestra en texto plano, permitiendo la escalada de privilegios.
Componente afectado	Sistema de archivos local (<code>/home/kay/.ssh/id_rsa</code> y <code>/home/kay/pass.bak</code>)
Categoría (OWASP / CWE)	OWASP A01:2021 (Broken Access Control) / CWE-732 y CWE-256
CVE (si aplica)	No aplica (Falla de permisos locales y gestión de credenciales)
CVSS estimado	☐ Bajo ☐ Medio ☒ Alto ☐ Crítico
Evidencia (captura / comando)	Archivos de registro en repositorio: <code>bitacora/john_kay.txt</code> (sanitizado) y captura <code>evidencias/post/post_H-05.png</code> .
Herramienta utilizada	OpenSSH, ssh2john y John the Ripper
Impacto en la Tríada CIA	☒ Confidencialidad ☒ Integridad ☒ Disponibilidad
Salvaguarda propuesta	1. Restringir los permisos del directorio SSH y la clave privada (<code>chmod 700 /home/kay/.ssh</code> y <code>chmod 600 /home/kay/.ssh/id_rsa</code>). 2. Restringir el acceso al directorio personal (<code>chmod 750 /home/kay</code>). 3. Eliminar el archivo <code>pass.bak</code> en texto claro y regenerar las claves SSH con una frase de paso robusta.
Riesgo residual tras aplicar	☒ Bajo ☐ Medio ☐ Alto

Entorno B: Evaluación Nivel 2 (Elección) — Sala Vulnversity (IP: 10.66.142.132)

Campo	Valor
ID del hallazgo	H-06
Fase	☐ Reconocimiento ☐ Escaneo ☒ Explotación ☐ Post-explotación
Descripción	Carga ilrestrlcta de archivos peligrosos mediante validación por lista negra insuficiente en formulario web. El formulario de carga ubicado en el directorio <code>/internal/</code> aplica una validación que bloquea extensiones estándar <code>.php</code> , pero no restringe extensiones ejecutables alternativas interpretadas por el servidor web (como <code>.phtml</code>). Se preparó un payload a partir de <code>/usr/share/webshells/php/php-reverse-shell.php</code> renombrado con extensión <code>.phtml</code> , el cual fue subido e invocado directamente en el directorio público <code>/internal/uploads/</code> , comprometiendo la cuenta de servicio <code>www-data</code> .
Componente afectado	Aplicación web y servidor Apache (<code>http://10.66.142.132:3333/internal/</code>)
Categoría (OWASP / CWE)	OWASP A04:2021 (Insecure Design) / CWE-434 (Unrestricted Upload of File with Dangerous Type)
CVE (si aplica)	No aplica (Debilidad en el diseño y validación de la aplicación web)
CVSS estimado	☐ Bajo ☐ Medio ☒ Alto ☐ Crítico (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N)
Evidencia (captura / comando)	Preparación del payload: captura <code>evidencias/explotacion/explotacion_H06_prep.png</code> y <code>explotacion_H06_payload.png</code> . Carga y conexión interactiva: captura <code>evidencias/explotacion/explotacion_H-06.png</code> .
Herramienta utilizada	Navegador web Firefox y Netcat v1.10
Impacto en la Tríada CIA	☒ Confidencialidad ☒ Integridad ☐ Disponibilidad

Salvaguarda propuesta	pro-	1. Implementar validación estricta basada exclusivamente en listas blancas de extensiones permitidas (<i>whitelisting</i>) y comprobación de <i>magic bytes</i>. 2. Deshabilitar la ejecución de scripts en el directorio de almacenamiento mediante configuración del servidor web (<code>php_admin_flag engine off</code> y <code>Options -ExecCGI</code>). 3. Almacenar los archivos fuera de la raíz web (<i>web root</i>) y renombrarlos utilizando identificadores pseudoaleatorios (UUIDs).
-----------------------	------	--

Riesgo residual tras aplicar	☒ Bajo ☐ Medio ☐ Alto
------------------------------	---

Campo	Valor
ID del hallazgo	H-07
Fase	☐ Reconocimiento ☐ Escaneo ☐ Explotación ☒ Post-explotación
Descripción	Asignación insegura de permisos SUID en binario administrativo del sistema (/bin/systemctl). Durante la fase de auditoría local de privilegios, se detectó que el gestor de servicios del sistema operativo poseía el bit SUID activo (<code>-rwsr-xr-x</code>). Esta mala configuración permite a usuarios locales no privilegiados invocar comandos administrativos y registrar o ejecutar servicios en segundo plano bajo el contexto del superusuario (root), derivando en una escalada total de privilegios locales.
Componente afectado	Sistema operativo base y gestor de servicios (/bin/systemctl)
Categoría (OWASP / CWE)	OWASP A05:2021 (Security Misconfiguration) / CWE-732 (Incorrect Permission Assignment) / CWE-250
CVE (si aplica)	No aplica (Mala configuración de permisos locales del sistema de archivos)
CVSS estimado	☐ Bajo ☐ Medio ☐ Alto ☒ Crítico (CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H)
Evidencia (captura / comando)	Auditoría local de binarios SUID: <code>find / -type f -perm -04000 -ls 2>/dev/null</code> . Captura asociada: <code>evidencias/post/post.H-07.png</code> .
Herramienta utilizada	GNU find y utilidades nativas de Linux

Impacto en la Tríada CIA ☒ Confidencialidad ☒ Integridad ☒ Disponibilidad

Salvaguarda propuesta ☒ 1. Retirar inmediatamente el bit SUID del binario administrativo ejecutando `chmod u-s /bin/systemctl`.
 2. Implementar delegación granular y auditada de privilegios a través de directivas en `/etc/sudoers`.
 3. Ejecutar auditorías automatizadas periódicas sobre la integridad y atributos de archivos en directorios de binarios estándar (`/bin`, `/usr/bin`).

Riesgo residual tras aplicar ☒ Bajo ☐ Medio ☐ Alto

0.4. Resumen ejecutivo de hallazgos

Severidad	Cantidad	Basic Pentesting (Nivel 1)	Vulnversity (Nivel 2)
Crítico	1	—	H-07
Alto	4	H-02, H-04, H-05	H-06
Medio	1	H-01	—
Bajo	1	H-03	—
Subtotales	7	5 hallazgos	2 hallazgos

0.5. Post-pentesting: Recomendaciones

Recomendaciones técnicas (parches y configuraciones)

- Prioridad Crítica — Remediación de permisos SUID (Vulnversity):** Retirar el bit SUID de utilidades del sistema como `/bin/systemctl` (`chmod u-s /bin/systemctl`) para asegurar que las cuentas de servicio locales no puedan invocar comandos con privilegios de superusuario.
- Prioridad Alta — Hardening de aplicaciones web y subida de archivos (Vulnversity):** Reemplazar el filtrado por listas negras por una validación estricta de extensiones permitidas (listas blancas) junto con el análisis de *magic bytes*. Deshabilitar la ejecución de scripts en las rutas de subida (`/uploads/`) mediante la directiva `php_admin_flag engine off` en Apache.
- Prioridad Alta — Endurecimiento de accesos remotos (Basic Pentesting):** Deshabilitar la autenticación por contraseña en SSH (`PasswordAuthentication no`), instalar Fail2Ban para mitigar intentos de fuerza bruta y corregir los permisos de directorios personales (`chmod 700 ~/.ssh` y `chmod 600 ~/.ssh/id_rsa`). En Samba, deshabilitar sesiones nulas (`restrict anonymous = 2`).
- Prioridad Media — Depuración de entornos web en producción:** Eliminar directorios de prueba (`/development/`), notas internas y archivos de respaldo (`pass.bak`) en texto

claro. Restringir puertos no estándar mediante firewall (`ufw`).

5. **Prioridad Baja — Configuración de cabeceras y banners:** Configurar `ServerTokens` `Prod`, `ServerSignature` `Off` y definir cabeceras de seguridad HTTP (HSTS, CSP, X-Content-Type-Options).

Recomendaciones administrativas (políticas y procesos)

1. **Política de control de cambios y despliegue seguro:** Implementar procesos de revisión de código (*code review*) y pruebas estáticas de seguridad (SAST) en los formularios de carga de archivos antes de su pase a entornos productivos.
2. **Auditorías periódicas de integridad del sistema operativo:** Establecer escaneos mensuales automatizados de permisos SUID/SGID y monitoreo de integridad de archivos críticos (usando herramientas como *AIDE* o *Tripwire*) para detectar desviaciones en binarios administrativos.
3. **Gestión corporativa de identidades y contraseñas:** Establecer una política corporativa estricta que prohíba el almacenamiento de contraseñas en archivos planos y regule el uso de frases de paso robustas para llaves SSH.

1. PROTOCOLO DE CONTINGENCIA

Escenario de falla

Durante la ejecución de escaneos activos de puertos, enumeración web automatizada o pruebas de carga de archivos sobre el servicio web (3333/TCP) y SSH, existe el riesgo operativo de provocar una saturación del pool de conexiones TCP/HTTP, agotamiento de recursos o bloqueo involuntario de cuentas legítimas de administración en el servidor de **INSECUR S.A.**, ocasionando la interrupción temporal del portal web o del servicio de archivos SMB.

Impacto sobre la continuidad del negocio

- **Procesos afectados:** Indisponibilidad de las aplicaciones web institucionales (Puertos 80 y 3333/TCP), interrupción del acceso a recursos compartidos del personal vía SMB (Puerto 445) y degradación del acceso remoto de administración por SSH (Puerto 22).
- **Tiempo estimado de afectación sin contingencia:** Entre 1 y 4 horas de inactividad operativa hasta el diagnóstico manual y reinicio de los demonios afectados.

Plan de respuesta

1. **Activación:** Detección mediante monitoreo de disponibilidad (pérdida de respuesta ICMP/TCP durante más de 60 segundos consecutivos). Se suspende inmediatamente toda ejecución de herramientas en la estación de auditoría.
2. **Contención:** En los primeros 15 minutos se aísla el tráfico de la interfaz de auditoría (`tun0`), se verifica el estado de recursos y demonios desde la consola de administración (`apache2`, `smbd`, `ssh`) y se liberan las sesiones colgadas.
3. **Recuperación:** Reinicio controlado de los servicios afectados (`systemctl restart apache2 smbd ssh`) o, en caso de inestabilidad persistente, ejecución de *rollback* restau-

rando el *snapshot* previo a la ventana de pruebas.

4. **Comunicación:** Notificación dentro de los primeros 10 minutos al Responsable de Seguridad (CISO) y a la Dirección de TI de INSECUR S.A. detallando la hora del incidente, la prueba ejecutada y el estado de restauración.
5. **Post-mortem:** Registro del evento en la bitácora técnica, análisis de logs (/var/log/auth.log y /var/log/apache2/error.log) y ajuste de tasas de envío e hilos concurrentes antes de reanudar la actividad.

RTO y RPO estimados

RTO (Recovery Time Objective): 15 minutos (reinicio de servicios o restauración de instantánea).

RPO (Recovery Point Objective): 0 horas (cero pérdida de datos mediante snapshot previo a la auditoría).

2. Anexos

Anexo A — Bitácora de comandos

Adjuntar los archivos de registro generados durante la práctica en el repositorio: bitacora/gobuster.txt, bitacora/gobuster_room2.txt, bitacora/enum4linux.txt, bitacora/hydra.txt, bitacora/john_kay.txt, bitacora/kay_hash.txt, bitacora/nikto.txt, bitacora/nmap_inicial.txt, bitacora/nmap_puertos.txt, bitacora/nmap_inicial_room2.txt, bitacora/nmap_puertos_room2.txt y bitacora/2026.pcapng (captura de tráfico de la sesión SSH de H-04, tomada sobre tun0).

Anexo B — Capturas de pantalla

Carpeta evidencias/ estructurada por fase. Para esta entrega se incluyen:

- evidencias/escaneo/escaneo_H-01.png, escaneo_H-03.png.
- evidencias/explotacion/explotacion_H-04.png, explotacion_H-04_shell.png, explotacion_H06_prep.png, explotacion_H06_payload.png, explotacion_H-06.png.
- evidencias/post/post_H-05.png, evidencias/post/post_H-07.png.

Anexo C — Hashes de las flags obtenidas

```

1 # Formato: flag_id sha256_hash
2 H-04 4f932f8233900b261522368e08aa4e3d9cf1fb68c3b3117ad496fa806bd25929
3 H-05 09e8f17c1d675b6f35fb1f45bf31efcd68e7dc0ca42cc0518d718f17fc625987
4 Vulniversity-User-Flag 131d258163f966bd450c26804cf3d9cf4a408713dd2f707f4a25fd8a9cba250d
5 Vulniversity-Root-Flag c6ec43896504a39523cc1ec5bc0dca74d1566373b50c6ea62aa0327fce1c62f2

```

Anexo D — Declaración ética firmada

Declaro que todas las actividades se realizaron dentro del alcance autorizado, en entornos controlados y con fines exclusivamente académicos.

Julieta Ruppert (Firma del estudiante)

04-10-2026 (Fecha)